

Brightcare_Incident_Response_Plan.pdf

Brightcare Digital Health · Confidential · For underwriting use only

INCIDENT RESPONSE PLAN

Brightcare Digital Health – Information Security

Policy ID: IS-IR-001 | Version: 5.1 | Effective: 2026-03-01

Owner: CISO | Next tabletop: 2026-11

CONFIDENTIAL – For underwriting and broker use only. Not for redistribution.

1. PURPOSE & SCOPE

Establish roles, severity criteria, containment, eradication, recovery, and notification for security incidents affecting Brightcare systems, data (including ePHI), and critical third parties.

2. IR TEAM (ON-CALL ROTATION)

Incident Commander Director, Security Operations
Technical Lead Staff SRE / Platform
Comms Lead VP, Customer Trust
Legal / Privacy General Counsel + DPO
Executive Sponsor CISO (escalate to CEO for Sev-1)
External retainers CrowdStrike Services; Foley cyber counsel

3. SEVERITY MATRIX

Sev-1 Confirmed ransomware / mass ePHI exfil / IdP takeover
!' page within 15m; exec bridge; legal on first call
Sev-2 Targeted intrusion / material availability loss >1h
Sev-3 Contained malware / policy violation with limited blast radius
Sev-4 Suspicious activity requiring investigation only

4. DETECTION SOURCES

CrowdStrike Falcon, Splunk correlation, GuardDuty, Okta risk signals, Proofpoint, AWS CloudTrail anomalies, customer-reported abuse.

5. RESPONSE PHASES

Identify !' Contain (isolate host / revoke tokens / block IoCs) !'
Eradicate !' Recover (from immutable backups if needed) !' Lessons learned
Evidence preserved under Legal hold; chain-of-custody logged in IR tool.

6. NOTIFICATION TRIGGERS

HIPAA breach assessment within 24h of discovery; OCR / individual notice per 45 CFR §164.404-408 when required. State AGs / multi-state counsel as advised. Cyber insurer notified per policy conditions (broker Marsh Specialty – hotline on binder). Customers under BAA: contractual notice windows (typically 24-72h).

7. RANSOMWARE PLAYBOOK (SUMMARY)

Do not pay without Legal + insurer approval. Preserve EDR telemetry. Prefer restore from Object-Lock backups; dual-path rebuild runbook. Credential reset for Okta + AWS root/break-glass after containment.

8. TRAINING & EXERCISES

Annual tabletop (last: 2026-02-19). Technical restore drill linked to DR program (last pass: 2026-06-12). Phishing simulations quarterly.

Approved: CISO Office | Board Risk Committee informed (2026-Q1 packet)